

Clase 305 — Capstone: operación Red Team end-to-end

Parte: **16 — Capstones y preparación de certificaciones** · Fuente: MITRE ATT&CK® · Red Team Development and Operations (Vest & Tubberville) 🕒 Duración estimada: **150 min** · Nivel: **Experto**

🎯 Objetivo

Ejecutar una **operación Red Team completa** contra tu laboratorio, simulando un adversario con objetivos de negocio (no solo "hackear máquinas"): reconocimiento, acceso inicial, establecimiento de C2, movimiento lateral, escalada, consecución de objetivos y evasión, todo mapeado a **MITRE ATT&CK**. Integra la Parte 9 (Red Team/C2), la Parte 8 (AD) y la Parte 5 (evasión/OPSEC), y produce un informe orientado a **mejorar la detección** del Blue Team.

⚠️ **Ética y legalidad:** operación **exclusivamente** contra infraestructura propia o con autorización escrita y alcance firmado. El uso de C2, malware o técnicas de evasión fuera de un laboratorio autorizado es delito. Documenta el permiso antes de empezar.

📄 Resultados de aprendizaje

Al finalizar, el alumno podrá:

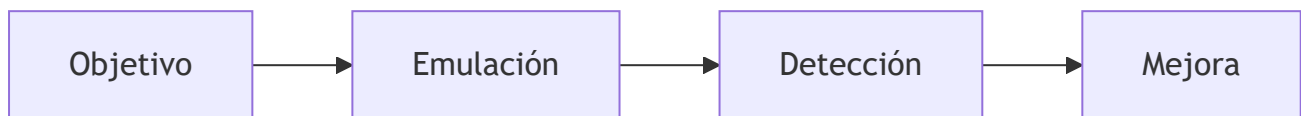
- 1. **Definir** objetivos y escenario de amenaza (threat emulation) de una operación.
- 2. **Desplegar** una infraestructura C2 con redirectores y OPSEC básica.
- 3. **Ejecutar** una cadena de ataque completa mapeada a ATT&CK.
- 4. **Evadir** controles básicos (EDR/AV) documentando cada decisión.
- 5. **Entregar** un informe con narrativa de ataque y recomendaciones de detección.

📖 Temas

#	Tema	Por qué importa
1	Threat emulation y objetivos	Simular un adversario real, no ruido
2	Infraestructura C2 y redirectores	OPSEC y resiliencia del canal
3	Acceso inicial (phishing/payload)	Primer punto de apoyo realista
4	Movimiento lateral (Parte 8)	Propagación en AD
5	Evasión EDR/AV (Parte 5)	Operar sin ser detectado
6	Objetivos y exfiltración	Demostrar impacto de negocio
7	Informe y purple teaming	Convertir el ataque en mejora defensiva

Explicación en profundidad

Una operación red team mide objetivos y controles bajo autorización; no maximiza acceso. Emulación, telemetría, seguridad operacional y cleanup son entregables. La clase convierte el objetivo en una evidencia evaluable, declara supuestos y reserva tiempo para revisión. El resultado profesional incluye lo que no se comprobó.



Caso razonado

El objetivo se cumple con una técnica menos invasiva. El equipo detiene escalamiento y conserva evidencia suficiente.

Glosario operativo

Término	Definición
Deconfliction	Coordinación para distinguir ejercicio de incidente real.
Evidencia	Resultado que otra persona puede revisar y relacionar con un criterio.
Retrospectiva	Revisión de decisiones, límites y siguiente mejora.

Criterio de dominio

El alumno domina la clase cuando planifica, ejecuta y comunica una evidencia completa, respeta alcance y puede defender sus decisiones ante una revisión.

Definiciones y características

- **Threat emulation:** reproducir el TTP de un adversario concreto (p. ej. un grupo APT). *Característica:* guía qué técnicas usar.
- **C2 (Command and Control):** canal para controlar implantes. *Característica:* debe ser resiliente y sigiloso.
- **Redirector:** servidor intermedio que oculta el C2 real. *Característica:* protege la infraestructura del operador.
- **OPSEC:** disciplina para no dejar rastros atribuibles. *Característica:* cada acción sopesa el riesgo de detección.
- **Movimiento lateral:** pivotar entre hosts con credenciales/técnicas. *Característica:* base del compromiso de dominio.
- **Purple teaming:** colaboración Red/Blue para mejorar detección. *Característica:* cierra el ciclo del capstone.

Herramientas y preparación

- Laboratorio con AD (GOAD/DetectionLab) y, si tienes, un EDR de prueba.

- C2: un framework de laboratorio (p. ej. **Sliver**, **Mythic** o **Havoc**) — usa solo en tu red.
- Redirectores: Nginx o `socat` en una VM intermedia.
- Movimiento lateral: `impacket`, `CrackMapExec`, `Rubeus`, `Certipy`.
- Registro: matriz ATT&CK Navigator para marcar técnicas ejecutadas.
- Plantilla de informe orientada a detección.

Laboratorio guiado

Solo en tu laboratorio o con autorización escrita.

1. **Define el escenario.** Elige un adversario a emular y su conjunto de TTP en ATT&CK Navigator; fija el objetivo ("comprometer el controlador de dominio y exfiltrar `secret.docx`").
2. **Despliega C2.** Levanta tu servidor (Sliver/Mythic) en una VM y un redirector Nginx delante; verifica el callback.
3. **Acceso inicial.** Genera un payload y simula su entrega (en tu laboratorio, sin víctimas reales); obtén el primer implante.
4. **Descubrimiento.** Enumera el host y el dominio (`whoami /all`, `BloodHound`) respetando OPSEC.
5. **Escalada y credenciales.** Abusa de una debilidad local; extrae credenciales con técnica coherente con el escenario.
6. **Movimiento lateral.** Pivota a otros hosts; documenta cada salto y su técnica ATT&CK.
7. **Evasión.** Si hay EDR, ajusta el implante (sleep/jitter, ofuscación) y anota qué evadiste y qué te detectó.
8. **Objetivo y exfiltración.** Alcanza el objetivo y simula la exfiltración por el canal C2.
9. **Purple team.** Con los logs generados (para la Clase 306), lista qué técnicas deberían haber alertado.
10. **Informe.** Redacta la narrativa de ataque, la matriz ATT&CK cubierta y recomendaciones de detección.

Ejercicios

1. Construye la capa ATT&CK Navigator del adversario emulado.
2. Diseña el diagrama de tu infraestructura C2 con redirector.
3. Documenta una cadena acceso inicial → Domain Admin con técnicas ATT&CK por paso.
4. Compara dos configuraciones de C2 (sleep/jitter) y su impacto en OPSEC.
5. Enumera 5 técnicas que un EDR debería detectar y por qué.
6. Escribe la narrativa de ataque para el resumen ejecutivo.

Reto verificable

Entrega un **informe de operación Red Team** (`informe-redteam.md`) con: escenario y objetivos, diagrama de infraestructura C2, narrativa de ataque paso a paso mapeada a ATT&CK, técnicas de evasión aplicadas y una tabla de **recomendaciones de detección** para el Blue Team. Adjunta la capa de ATT&CK Navigator.

Criterio de aceptación: la operación alcanza el objetivo definido, cada paso tiene su técnica ATT&CK, la infraestructura incluye al menos un redirector, y el informe entrega recomendaciones de detección accionables (no solo "hackeé X").

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
"El implante no llama a casa"	Redirector mal configurado; revisa el reenvío y el perfil C2.
"Me detecta el EDR al instante"	OPSEC pobre; ajusta sleep/jitter y evita binarios conocidos.
"No sé qué técnicas usé"	Sin registro; marca cada acción en ATT&CK Navigator en el momento.
"El informe solo cuenta el hackeo"	Falta valor defensivo; añade recomendaciones de detección.
"Rompí el dominio"	Acciones destructivas; usa snapshots y evita persistencia dañina.

Preguntas frecuentes

 **¿Red Team es lo mismo que pentest?** No. El pentest busca cobertura de vulnerabilidades; el Red Team emula un adversario con objetivos y sigilo, y mide la detección.

 **¿Qué framework C2 uso para aprender?** Sliver o Mythic son abiertos y bien documentados. Úsalos solo en laboratorio.

 **¿Necesito un EDR real?** Ayuda, pero puedes practicar OPSEC y detección con las herramientas de la Parte 10–11 sin uno comercial.

 **¿Cómo conecto esto con el Blue Team?** Los logs de esta operación alimentan el capstone de la Clase 306 (purple teaming).

Referencias

- MITRE ATT&CK®: <https://attack.mitre.org/>
- ATT&CK Navigator: <https://mitre-attack.github.io/attack-navigator/>
- Sliver C2: <https://github.com/BishopFox/sliver>
- Vest & Tubberville, *Red Team Development and Operations*.
- Red Canary Atomic Red Team: <https://github.com/redcanaryco/atomic-red-team>

Material descargable

-  [Guía en PDF](#) — versión imprimible de esta clase.
-  [Presentación \(PPTX\)](#) — deck para proyectar en clase.

Clase anterior

[Clase 304 — Preparación CISSP: los 8 dominios](#)

Siguiente clase

[Clase 306 — Capstone: detección Blue Team end-to-end](#)